

Fan Pricing — Diagnóstico & Decisões

Reunião 09/07/2026 · 15h–16h · foco V1 · Stéphanie, Igor, Leandro, Vitor

Estado atual

App **Next.js + Supabase** já em uso interno (propostas/orçamentos). Hoje é **single-tenant**, com isolamento **por usuário** (`created_by`) e RLS ativo. **Multi-tenancy é fase de produto (futuro), não V1.**

Buracos de segurança — corrigir já (baratos, não dependem de decisão de negócio)

- 1

Toda proposta é pública — a policy usa `using(true)`; o token só filtra no código. Qualquer requisição anônima lê **todas** as propostas. → fechar tabela + acesso por token via RPC.
- 2

Middleware não roda — o arquivo é `proxy.ts`, mas o Next só executa `middleware.ts`. A guarda de `/admin` está inativa — usuário comum acessa `/admin/users`. → religar como `middleware` + checar papel por rota.
- 3

service_role + registro aberto — `service_role` (bypassa RLS) em 8 arquivos; `/register` público cria conta para qualquer um. → auditar `service_role`; registro por convite/domínio.

4 decisões para hoje (destravam o resto)

1	V1 é single-tenant interno? Recomendação: sim — multi-tenant só com go de produto.
2	Fechar as 5 regras do motor: horas→% de alocação · overhead sobre MOD ou custo total · margem flutuante · ferramentas fixo ou overhead · formato do PDF.
3	Margem: 30% ou 32%? Divergência: schema tem 30% (0.30), Ata cita 32%.
4	Autorizar os fixes ■ já? São pequenos e independentes das decisões de negócio.

Linear: **Fan Pricing (FPNG)** — 10 issues · milestones V1 (Agora) → Confiabilidade (60d) → Preparar Produto (90d) → Multi-Tenant (120d).
Fontes: `supabase-schema.sql` · `src/proxy.ts` · `src/lib/supabase/admin.ts` · `admin/users/page.tsx` · `calculations.ts` · Ata 08/07.